STUDYROUTE / INTERNATIONAL TRACK

Security Self-Assessment

Permission tiers, control assurance and residual risk

SYNTHETIC-DATA DEMONSTRATOR / NOT PRODUCTION ASSURANCE

Source-based assessment with reproducible local evidence

No real money, live banking integration or independent certification

REPORT CONTENTS

01 Executive assessment

02 Scope, provenance & method

03 System & trust boundaries

04 Permission tiers & separation of duties

05 Identity & transaction safeguards

06 Data, AI & artifact protection

07 Audit integrity: the exact guarantee

08 Prioritized risk register

09 Residual risk & remediation

10 Verification results & evidence limits

11 Release gates & incident readiness

12 References & evidence locator

SR-SEC-2026-01 | Version 1.0

18 October 2026

Prepared for StudyRoute submission review • English edition

00 / VERIFIED AFTER EDITION 1.0

Final-submission update (edition 1.1)

The assessment in this document (edition 1.0, 18 October 2026) is unchanged: every result, count and risk below stands as written. This page adds read-only checks made later the same day, recorded in validation/final-verification.json (E07, produced by tools/final_verification.py), and supersedes edition 1.0's statement that the remote repository was not checked. The cover still reads Version 1.0; this page makes it edition 1.1.

Item	Result
Source identity	The remote main branch of NoobCrow/StudyRoute is commit bcce930ae0974712e922245878fd976b03a8938a, the commit this document covers. Edition 1.0 could not check the remote; this supersedes its statements that the remote HEAD was not checked. [E07]
Repository access	Public; default branch main. The README, the technical-documentation PDF and the deck load anonymously (HTTP 200). [E07]
Continuous integration	GitHub reports the workflow "ci" on that commit as success: docker, contracts, web, secret-scan, backend and dependency-audit all succeeded (run 39081290614). The job logs were not re-reviewed here. [E07]
Other branches	A branch named botkeep (3 commits, head e2c28a0c74b6) is on the remote and is not part of main. It was not assessed; this document still covers main only. [E07]
The one skipped test module	backend/tests/test_explainer_model.py is skipped because its fixture, backend/tests/data/explainer_cases.json, is excluded by the repository's .gitignore rule data/: it is absent from the public repository and from the archive. A fresh clone therefore collects 1,673 tests, runs 1,672 and skips the explainer quality-floor tests, which is exactly the edition 1.0 result. The authors report 1,678 tests (1,677 passed, 1 skipped) on a machine that has the fixture (docs/TEST_CASES.md; not re-run here). Adding the fixture to the repository is an open item for the maintainers and is not changed by this update. [E07]
Regulatory assumptions (SR-04)	Four study-abroad rules (one AD bank branch for the whole course, one academic year at a time, release per the institution's estimate, international cards for education) were read in the official Bangladesh Bank circular FEPD-1 No. 40 of 30 September 2026, section 10, and are marked verified in config/rules.yaml. The USD 2,000 a month living-cost figure is not in that text and stays unverified. This is the team's reading and no lawyer or AD bank has reviewed it, so SR-04 otherwise stands.
The team's Docker run (inherited, not re-run here)	Same day, in an Ubuntu 24.04 VM with Docker 29.1.3: the smoke checks, the 14-step demo (66 checks OK), the bank-review demo, a real-Chrome audit (48 of 48) and the hardened overlay (read-only filesystem, all capabilities dropped) passed. The run used the archive of commit 8d91cc8 with the two files of the later fix c9d044b copied in; it was not a fresh archive of bcce930. It first found that the trained explainer reworded the assistant's questions (3 demo checks failed; the CI docker job had failed 4); the fix is part of bcce930. Raw output: inherited/submission/evidence/docker_2026-10-18/ and docker_run.txt (H04).
Corrections to edition 1.0	Section 10 calls the 1,678 backend count an older summary. It is the current count on a machine that has the explainer fixture; a fresh clone collects 1,673, which is the figure this document reports. [E07]

Not changed by this update — The permission tiers, the control review, the risk register SR-01 to SR-10, the release gates G1 to G8, every count and result in section 10, and the conclusion that the evidence supports a controlled synthetic-data demonstration only.

01 / DECISION & ASSURANCE

Executive assessment

StudyRoute is a synthetic-data demonstrator for cross-border student payments. Its security design separates deterministic financial calculations, AI-assisted preparation and human authorization. The reviewed source enforces significant safeguards, but the evidence supports a controlled sandbox demonstration—not production payment processing or a regulatory compliance claim. [C01–C10]

Assessment area	Conclusion
Authorization	Role + token scope + ownership checks; human-only payment approval with action-bound step-up.
Transactional integrity	Idempotency, state-machine guards, summary hashes and audit records tested locally.
Data protection	Field-level authenticated encryption and session controls are implemented; operator key custody remains a trust boundary.
AI safety	AI is constrained by domain permissions and tool restrictions. Model accuracy is not treated as authorization.
Deployment readiness	Conditional for isolated synthetic demonstration. Public HTTPS, operational hardening and live rails are not verified.

Evidence established for this edition

Fresh backend regression: **1,672 passed / 0 failed / 0 errors / 1 skipped**. Fresh HTTP API demonstration: **66 checks passed, 0 failed**. The local audit verified **76 events**; editing event 75 was detected and restoration returned PASS. All four local model components loaded. These are local results on the supplied main-branch archive, not Botkeep deployment results. [E01–E06]

No independent certification
This is a source-based self-assessment and reproducibility review. It is not an independent penetration test, banking authorization, ISO certification or guarantee that no vulnerabilities exist. No project owner has signed a risk acceptance as part of this report.

02 / ASSESSMENT BOUNDARY

Scope, provenance & method

Item	Reviewed scope
Source package	StudyRoute-main.zip; 834 archived files; 116,683,391 uncompressed bytes.
Repository context	NoobCrow/StudyRoute, main archive supplied by the project owner.
Archive commit identifier	bcce930ae0974712e922245878fd976b03a8938a
Review date	18 October 2026 (UTC); report edition 1.0.
Execution environment	Linux x86_64; Python 3.13.14; reused local dependency environment.
Test boundary	Disposable SQLite test databases and one isolated loopback HTTP API instance.

Procedure

- Inspect security-critical code and existing design/risk documents; reconcile contradictory summaries against raw evidence.
- Run the complete supplied backend suite, the repository scanner and the four local model loaders; preserve logs and JUnit output.
- Execute the supplied 14-step sandbox flow against a fresh local API with all local model modes set to auto, then perform the supported tamper/restore demonstration.
- Recompute both supplied and fresh audit chains outside the running API; publish source identity and evidence hashes.

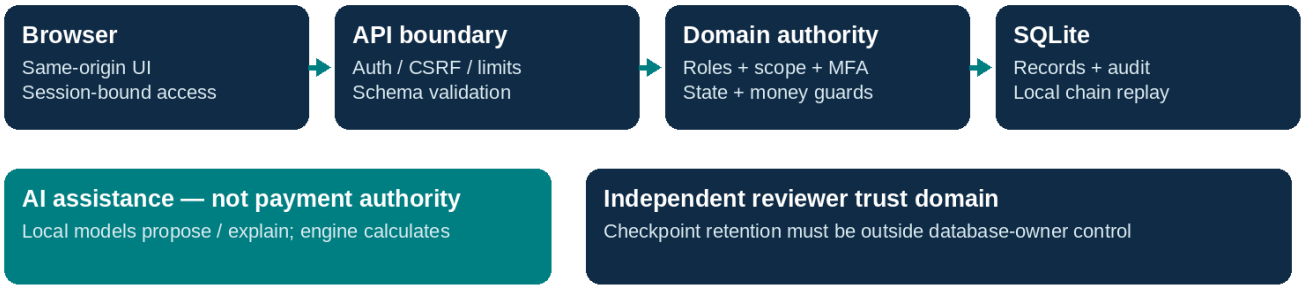
Explicit exclusions

No external penetration testing, internet-facing TLS assessment, load testing, new vulnerability-advisory database scan, clean-machine dependency installation, model retraining, new blind study, real provider call, real KYC/sanctions integration or actual financial settlement was performed. Docker, frontend builds and browser probes were not rerun for this edition. [E01–E06; H01–H04]

Branch and deployment boundary
The Botkeep branch uses a separate packaging/bootstrap path and was still being imported during this work. This report assesses the supplied main archive; it does not certify that deployment, its Release downloader, environment variables or public domain.

03 / THREAT MODEL

System & trust boundaries



Protected asset	Principal threats / boundary
Identity and sessions	Credential guessing, stolen bearer tokens, session replay and cross-site requests. Browser → API.
Payment instructions	Unauthorized approval, stale quote, changed recipient/amount, duplicate execution. API → domain.
Sensitive fields and provider keys	Database copying, logs, cross-user disclosure, optional third-party AI disclosure. Domain → storage/provider.
Audit and ledger records	Incomplete edits, reordered events, coordinated database-owner rewrite. API → SQLite → independent reviewer.
Models and rule configuration	Artifact replacement, parser flaws, model error, stale or unverified financial assumptions. Repository → runtime.

Attacker assumptions

Consider unauthenticated clients, authenticated users from another household, compromised parent/student sessions, malicious prompt/document content, forged provider events, and an operator or database owner with privileged filesystem access. These attackers do not have equal capabilities; in particular, a database-owner limitation is not evidence of an unauthenticated remote exploit. [C01–C09]

Important exception
The reviewer/admin is intentionally cross-household for review and administration. Parent, student and delegated AI access are household-scoped. A reviewer cannot replace the parent's payment approval. [C01; C03]

04 / AUTHORIZATION

Permission tiers & separation of duties

Effective authorization requires the intersection of role permissions, issued token scopes and object ownership, plus action-specific guards. UI hiding is not the authority boundary. The domain layer provides a separate explicit AI approval refusal. [C01; C03]

Capability	Parent	Student	Reviewer	AI
Create / read quotes	Yes	Yes	Read	Yes
Read payments	Own HH	Own HH	All	Delegated HH
Draft / request approval	Yes	No	No	Granted*
Approve payment	MFA	No	No	Never
Cancel payment	Yes	No	No	No
Reject payment	Yes	No	Yes	No
Create recipient	Yes	Yes	No	No
Allowlist recipient	MFA	No	No	No
Review KYC / bank decision	No	No	Yes**	No
Write configuration	No	No	Yes	No
Verify audit / anchor head	No	No	Yes	No
Bank transfer / escrow write	MFA	No	No	No
Escrow freeze / unfreeze	No	No	Yes	No
Submit review response	Yes	No	No	No

HH = household. *The AI service role contains draft/request permissions; the conversational tool path is narrower and proposes drafts rather than exposing all role capabilities. Do not describe the entire AI role as read-only. **A bank review decision requires its own payment-bound MFA scope; a positive review does not itself approve or settle a payment. [C01; C07]

Full machine-derived permission matrix

The evidence bundle includes validation/rbac-matrix.json, generated directly from ROLE_PERMISSIONS. This compact report highlights decision-critical permissions rather than reproducing a potentially stale hand-maintained matrix. Relevant checks include test_rbac.py, test_api_roles.py, test_api_ai_rbac.py, test_security_households.py and test_bank_review.py. [E01; E06]

05 / CONTROL REVIEW — PART I

Identity & transaction safeguards

Control	Implementation / boundary	Evidence
Authentication	Argon2id password hashing; ES256 access tokens; issuer/audience/expiry checks; legacy refresh rotation with reuse-family revocation. Default access lifetime 900 seconds.	C02; E01: test_api_auth.py
Browser session	Opaque HttpOnly, SameSite=Strict cookie; Secure in production; absolute expiry; server-side hashed session; access JWT bound to active cookie session.	C02; E01: test_browser_session.py
CSRF boundary	Browser authentication endpoints require trusted exact Origin and X-StudyRoute-Browser header; cross-site browser authentication rejected.	C02; E01: test_browser_session.py
Step-up authorization	Fresh, single-use proof bound to user, object and action; nominal five-minute validity; fixed sandbox MFA is not production-strength verification.	C02/C03; E01: test_api_payment_guards.py
Approval consistency	Current approval summary hash and recipient context checked; changed inputs invalidate approval; state transitions restricted.	C03; E01: test_api_payment_guards.py
Duplicate prevention	Caller-scoped UUID idempotency keys; same-body replay returns prior result; different body conflicts; optimistic locking and concurrency regression.	C03; E01: test_api_idempotency.py
Provider callback	HMAC-SHA256 over timestamp and raw body; constant-time comparison; 300-second freshness; event de-duplication; provider/payment matching.	C04; E01: test_api_webhooks.py

Interpretation
A passing guard test demonstrates the tested branch and fixture, not every deployment configuration. Many regression fixtures use a fake clock, reduced password-hash cost and disabled background/network behavior; they are not latency or brute-force performance benchmarks. [E01; backend/tests/helpers.py]

06 / CONTROL REVIEW — PART II

Data, AI & artifact protection

Sensitive data at rest

FieldCipher uses AES-256-GCM, fresh 12-byte random nonces and context-bound authenticated data. Selected sensitive fields, document text and saved AI credentials use this helper; this is not whole-database encryption. Some display metadata stays plaintext, and legacy plaintext document rows remain readable. Possession of both the database and encryption key defeats confidentiality. [C05; E01: test_documents_at_rest.py, test_saved_ai_connection.py]

AI cannot be the payment authority

Message/document policy checks, restricted tools, deterministic calculations, fact/number validation and guarded local explanations form layered controls. The local reader and dialogue policy propose; the risk model routes to human review; only a human parent approves a payment. No model benchmark is substituted for the domain authorization checks. [C01; C07–C08]

Optional external AI

The fresh demonstration used local components with ASSISTANT_CLOUD_ENABLED=false. Optional user/provider connections create a separate egress boundary: masking lowers exposure but cannot prove that all sensitive context has been removed or control provider retention. Consent, provider terms, data minimization and outbound restrictions require operator review. Live provider calls were not tested. [C05; C07; E06]

Model supply chain

Model and policy manifests use SHA-256 checks. These establish consistency with a trusted manifest, not publisher authenticity: an attacker able to replace both artifacts and manifests can substitute them. ONNX avoids pickle-style object deserialization but still relies on native parsers/runtime code; it is not a guarantee that arbitrary model files are safe. [C08; C10]

Deployment consideration — separate from this scope
The planned GitHub Release download needs its own pinned-hash verification, trusted source configuration, resource limits and failure handling. It requires startup egress even when later inference is local. No such remote download was executed for this main-source assessment.

07 / TAMPER EVIDENCE

Audit integrity: the exact guarantee



Two distinct experiments: fresh single-row tamper; source/test-defined coordinated rewrite.

A local simulated chain is not an independently immutable audit anchor.

Each audit event covers the preceding hash and canonical event fields. Application/database triggers restrict ordinary updates and deletes. Fresh verification returned PASS for 76 events; a deliberate edit to amount_minor at sequence 75 returned HASH_MISMATCH, and restoring the row returned PASS. Independent offline recomputation agreed with both the supplied 75-event chain and fresh 76-event chain. [C06; E03; E05]

Where the guarantee stops

- A local audit hash chain detects inconsistent alteration. It does not prove that the underlying economic event was truthful.
- The audit events and replayable simulated-chain log share SQLite. A privileged owner can rewrite and rehash both consistently.
- The existing coordinated-rewrite regression intentionally demonstrates that both local checks can pass. This is an acknowledged trust limitation, not a failed claim of external immutability.
- A separately retained trusted-prefix checkpoint can expose rewrite or truncation of the recorded prefix only if the attacker cannot replace that checkpoint. A different directory or read-only mode on the same administrator-controlled host does not establish independence.

No blockchain overclaim

The sandbox uses an in-memory py-evm chain with persisted replay. No external validator set, public/consortium deployment or independently immutable timestamp service was verified. Production controls should use independently administered checkpoint retention and monitoring. [C06; H01]

08 / HIGH-PRIORITY PRODUCTION GATES

Prioritized risk register

Priorities are qualitative judgments of what must be resolved before real-money or real-person deployment. They are not CVSS scores, independent vulnerability ratings or evidence that each scenario was exploited. Cross-references preserve continuity with the supplied R1–R55 register. Proposed owners have not formally accepted these actions. [C10]

SR-01 | Demo identity and environment misuse — High

Residual exposure: Public demo hints, shared sandbox credentials and fixed MFA are intentional demo shortcuts. **Required action:** Disable shared accounts/hints; provision named users and real enrollment/step-up; isolate evaluation access. **Proposed owner:** Security lead + operator. Original register: R1, R29.

SR-02 | Secret custody and earlier exposure — High

Residual exposure: Historical notes identify credentials in earlier workspace material. Clean source scans cannot revoke or prove deletion of prior copies. **Required action:** Owner revocation; separate key custody; rotation/migration plan; verify encrypted backup restoration. **Proposed owner:** Repository owner + operator. Original register: R13, R46, R49, R55.

SR-03 | Privileged audit rewrite — High

Residual exposure: Local database and simulated-chain logs share one administrative trust domain. **Required action:** Independently protected checkpoints; log export/retention and missing-checkpoint alerts; restricted database privileges. **Proposed owner:** Platform + security lead. Original register: R7, R8, R22, R23.

SR-04 | Unverified regulatory / financial assumptions — High

Residual exposure: Invented bank rails, quotes, sanctions and some thresholds are not production banking rules or legal advice. **Required action:** Keep synthetic labels; use authoritative validated rules and licensed/supervised integrations before real use. **Proposed owner:** Product + regulated partner. Original register: R11, R12, R17, R19–R21, R26, R41, R43, R51.

SR-05 | Public deployment not validated — High

Residual exposure: TLS, reverse-proxy trust, cookie origin, data persistence, restore and operational controls were not verified on Botkeep. **Required action:** Review ingress; verify HTTPS and CSRF end to end; test restore; restrict demonstration access. **Proposed owner:** Deployment operator. Original register: R4, R5, R30, R31.

Risk disposition
Controls in the sandbox lower ordinary application-level risk; they do not close these production gates. No risk acceptance signature or production go-live approval is implied.

09 / MEDIUM-PRIORITY ACTIONS

Residual risk & remediation

SR-06 | AI error and malicious instructions — Medium

Residual exposure: Heuristic filters and statistical models miss some attacks; guarded wording is not a proof of factual safety. **Required action:** Retain deterministic gates, human approval and model-free fallback; expand adversarial and representative evaluation. **Proposed owner:** AI + security lead. Original register: R9, R10, R18, R32, R34, R35, R39, R44, R53, R54.

SR-07 | Model / dependency substitution — Medium

Residual exposure: Hash checks depend on trusted manifests; native model runtimes and development tools remain supply-chain attack surfaces. **Required action:** Protected reviews; signed releases/manifests; fresh SBOM/advisory checks for deployed image; controlled egress. **Proposed owner:** Maintainer + release lead. Original register: R14, R27, R33, R36, R38, R40, R42, R50.

SR-08 | Privacy, retention and external providers — Medium

Residual exposure: Plain display metadata and legacy rows remain; external AI retention/behavior is outside local control. **Required action:** Data inventory/retention; migrate legacy rows; consent and vendor review; remove data from logs and artifacts. **Proposed owner:** Privacy + product lead. Original register: R15, R37, R45, R46, R48, R49, R55.

SR-09 | Scale, abuse and identity operations — Medium

Residual exposure: Rate limits are process-local; no external identity lifecycle or distributed abuse controls are established. **Required action:** Shared rate-limit store; account lifecycle and recovery; monitor abuse and session revocation. **Proposed owner:** Platform + identity lead. Original register: R2, R3, R6, R16, R28, R47.

SR-10 | Reviewer and privileged workflow abuse — Medium

Residual exposure: The demo reviewer has broad cross-household visibility; real mandates and dual control are not established. **Required action:** Named reviewers; least-privilege scoping; escalation and dual review for sensitive decisions. **Proposed owner:** Operations + security lead. Original register: R24, R25, R52.

Assessment corrections carried into this edition

The inherited “AI can only quote” wording is distinguished from the broader AI service-role permission set. ONNX is not described as immune to runtime vulnerabilities. Prompt filtering is not described as guaranteeing harmless output. Historical zero-advisory checks are not presented as a current clean dependency bill of health. [C01; C08; C10; H01]

10 / WHAT WAS ACTUALLY CHECKED

Verification results & evidence limits

Evidence class	Observed result	Interpretation
Fresh backend suite	1,672 passed / 0 failed / 0 errors / 1 skipped	Supplied tests on exact extracted source; raw JUnit/logs included.
Fresh local HTTP flow	66 OK; 0 FAIL; exit 0	14 steps, simulated provider/financial services, real local API.
Fresh tamper experiment	PASS → FAIL at 75 → PASS	76-event baseline; mutation/restoration in disposable database only.
Independent recomputation	Supplied 75 / fresh 76 events valid	Canonical hashing; excludes derived amount_display display field.
Fresh model load	Reader + policy + risk + local explainer	Components loaded; not a fresh quality/safety benchmark.
Source scanner	Exit 0; no configured-pattern findings	Pattern-based source scan; not Git-history, binary or secret-revocation proof.
Inherited probes	146/146; 8/8; 42/42; 14 defended; 48/48	Team-authored historical tools; not rerun or independent pentest.

Do not add overlapping test counts

The supplied release record contains 1,542 backend cases, plus focused 42-case and 53-case runs. These runs overlap and represent different snapshots/scopes; older summaries also cite 1,678 backend cases. This edition uses the fresh complete-suite JUnit result as its primary backend count, and keeps inherited results separate. [E01; H01; C10]

Sampling and assumptions
The explainer quality-floor module was skipped because its cases fixture is absent; model loadability was checked separately. Positive tests and limited hostile-input corpora do not establish exhaustive safety. The test harness is team-authored; representative user studies, independent attack testing and verification of the actual public deployment remain open.

11 / BEFORE ANY PUBLIC OR REAL-DATA USE

Release gates & incident readiness

Gate	Acceptance evidence required	Status in this review
G1 — Secret custody	Owner revocation record; independent key storage; recoverable encrypted backups.	Not established
G2 — Identity and access	Named accounts, real MFA enrollment/recovery; scoped reviewer access; admin audit.	Sandbox controls only
G3 — HTTPS and ingress	Actual origin/cookie/CSRF checks; trusted proxy policy; backend port isolation.	Not tested remotely
G4 — Persistence and continuity	Restore drill for DB + encryption/signing material; recovery objectives and incident owner.	Not tested
G5 — Integrity supervision	Independently retained checkpoint + alert on missing interval and failed verification.	Manual design only
G6 — Supply chain	Deployed-image dependency scan, SBOM, signed artifacts; approved model manifests.	No fresh advisory audit
G7 — Real-world integration	Licensed partners, reconciled settlement, KYC/sanctions, legal/privacy assessment.	Out of scope
G8 — Independent assurance	Threat-led assessment, retest of findings and deployment security review.	Not performed

Minimum incident procedure

- Restrict affected access and preserve logs/checkpoints before modifying records; do not destroy evidence by reseeding or resetting databases.
- Revoke sessions and affected provider credentials. Preserve the encryption key needed to recover existing ciphertext; plan re-encryption rather than blind key replacement.
- Check audit prefixes against an independently held checkpoint; reconcile simulated/real financial records using the correct integration boundary.
- Restore from a verified backup in an isolated environment; retest controls and record the operator’s release decision.

Disposition
Proceed only as a controlled synthetic-data evaluation subject to operator approval. This report does not approve public production operation, real payment processing or legal compliance.

12 / TRACEABILITY

References & evidence locator

Bracketed identifiers link claims to source paths or bundled raw evidence. The original repository source is the supplied archive; no live remote HEAD assertion is made. Fresh results are located under validation/ in the companion evidence bundle. The full catalogue and per-file hashes are in EVIDENCE_INDEX.md and SHA256SUMS.txt.

ID	Reference
C01	Authorization and household isolation — backend/app/domain/rbac.py; backend/app/api/deps.py; backend/app/domain/auth.py
C02	Sessions, CSRF and credentials — backend/app/core/browser_session.py; backend/app/api/routes_auth.py; backend/app/domain/auth.py
C03	Payment safeguards and concurrency — backend/app/domain/payments.py; backend/app/domain/state_machine.py; backend/app/api/idempotency.py
C04	Provider event validation — backend/app/providers/webhooks.py; backend/app/api/routes_webhooks.py
C05	Encryption, redaction and secrets — backend/app/core/crypto.py; backend/app/core/secret_store.py; backend/app/core/logging.py; backend/app/domain/documents.py
C06	Audit chain and checkpoint boundary — backend/app/audit/chain.py; backend/app/audit/service.py; scripts/audit_checkpoint.py; docs/AUDIT_TRUST_BOUNDARY.md
C07	AI execution boundaries — backend/app/ai/guards.py; backend/app/ai/tools.py; backend/app/ai/orchestrator.py; backend/app/ai/number_guard.py; backend/app/ai/masking.py
C08	Local models and governance — backend/app/ai/nlu/runtime.py; backend/app/ai/dialogue/policy.py; backend/app/ai/risk/scorer.py; backend/app/ai/explainer/; docs/AI_RISK.md
C09	Runtime and deployment configuration — backend/app/core/config.py; docker-compose.yml; docker-compose.hardened.yml; web/nginx.conf; backend/app/api/middleware.py
C10	Original risk register and design — docs/SECURITY_SELF_ASSESSMENT.md; docs/SECURITY.md; docs/SECURITY_TESTING.md

Primary fresh references: E01 regression; E02 local API run; E03 audit/tamper; E04 financial/escrow; E05 provenance/recomputation; E06 source scan/model loading. Historical references H01–H04 remain explicitly inherited. See the companion Execution Evidence Report for their exact scope.

Source identity
Archive SHA-256: 4e6ce74cdafa51e4fa577813444d1f52c7d1d0098a7338b176005b415574134a. Source identifier: bcce930ae0974712e922245878fd976b03a8938a. These identifiers bind the assessment to this archive—not to subsequent commits or a different deployment branch.